

re_S24_A1_SL6_backend

Entrega no AVA

Nome: _____ Turma: _____

Título da atividade: Configurando servidores seguros

Contexto

1. HTTPS

HyperText Transfer Protocol Secure (HTTPS) é um protocolo que utiliza SSL/TLS para garantir a comunicação criptografada entre cliente e servidor, protegendo dados sensíveis contra interceptações e adulterações.

Boas práticas

- Obtenção e instalação de certificados SSL/TLS válidos.
- Configuração de redirecionamentos para forçar o uso de HTTPS.
- Monitoramento contínuo da validade e revogação dos certificados.

Exemplo prático:

Em um ambiente de produção, o servidor deve estar configurado para redirecionar automaticamente todas as requisições HTTP para HTTPS, garantindo a integridade e a privacidade dos dados trafegados.

2. Firewalls

Firewalls atuam como barreiras de segurança que controlam o tráfego de rede, permitindo ou bloqueando conexões com base em regras preestabelecidas para prevenir acessos não autorizados.

Boas práticas

- Configuração de regras específicas para limitar o acesso apenas a serviços essenciais.
- Utilização de firewalls de rede e de host para múltiplas camadas de proteção.

- Atualização periódica das regras de firewall conforme as ameaças evoluem.

Exemplo prático:

Um servidor web deve permitir apenas conexões nas portas 443 (HTTPS) e 80 (HTTP, se necessário para redirecionamento), bloqueando todas as outras portas para minimizar vetores de ataque.

3. Hardening de servidores

Hardening refere-se ao conjunto de medidas para fortalecer a segurança do servidor, reduzindo vulnerabilidades e minimizando a superfície de ataque.

Boas práticas

- Remoção de serviços desnecessários e fechamento de portas não utilizadas.
- Aplicação de patches e atualizações de segurança de forma contínua.
- Configuração de políticas de acesso restritas e auditorias de segurança.

Exemplo prático:

A aplicação de um checklist de hardening pode incluir a desativação de contas padrão, restrição de acesso via SSH a usuários autorizados e o uso de sistemas de detecção de intrusão.

Roteiro da atividade

Cenário:

Imaginem que vocês são responsáveis pela configuração de um servidor web de uma aplicação crítica.

Etapa 1 – Elaborem um plano detalhado que aborde:

- a implementação do HTTPS com certificados válidos e redirecionamento automático;

- a configuração de firewalls para restringir o tráfego apenas às portas necessárias;
- um checklist de hardening para eliminar serviços desnecessários e reforçar o acesso.

Etapa 2 – Redijam um documento com o plano de segurança do servidor, justificando cada escolha, com base nas melhores práticas apresentadas, e identificando os pontos críticos para monitoramento de forma clara e aplicável à realidade de ambientes de produção.

Etapa 3 – Resposta a uma situação realista:

Agora, imaginem que sua equipe recebe a seguinte mensagem no Slack:

"Equipe, recebemos um alerta de que alguns clientes ainda estão acessando nosso site via HTTP e não HTTPS. Precisamos revisar nossa configuração de segurança para assegurar a confidencialidade e a integridade dos dados dos usuários. Como vocês sugerem que ajustemos nossas práticas com base no nosso plano de segurança?"

Com base no plano elaborado, respondam às seguintes perguntas:

- A. Como vocês garantiriam que todas as requisições sejam redirecionadas para HTTPS? E qual é a importância dessa medida?
- B. Que ações vocês implementariam no firewall para reforçar a segurança do servidor?
- C. Quais medidas de hardening vocês consideram essenciais para reduzir a superfície de ataque do servidor?
- D. Como a comunicação entre a equipe de segurança e os desenvolvedores pode ser melhorada para responder rapidamente a alertas como esse?